

Luiss

Libera Università Internazionale
degli Studi Sociali Guido Carli

Project Guidelines

Data Privacy and Security

Data Science and Management (DASMA)

LUISS



Attending students: project (33% of the final score)

The project:

- is done individually
- involves the study of **one** real-world vulnerability
- is submitted as **one** 15 pages PDF report:
 - description of the affected program (e.g., architecture, components, implementation details, etc.)
 - description of the vulnerability type (e.g., recap of what is a SQL injection)
 - description of the vulnerability (e.g., how it works, where it is located in the code, etc.)
 - exploitation of the vulnerability (e.g., step by step for the reproduction, discussion of the exploit details, etc.)
 - reproduction of the vulnerability in a docker environment (e.g., detailed instructions to reproduce the vulnerability, output of the exploit, etc.)
 - mitigation of the vulnerability (e.g., how to fix the vulnerability, code changes, etc.)
 - reproduction of the fix in a docker environment (e.g., detailed instructions to reproduce the fix, output of the exploit, etc.)
- is evaluated based on a 0-30 points scale:
 - 26 points for the report
 - 4 points for reproduction environment

Non-attending students: project (50% of the final score)

The project:

- is done individually
- involves the study of **two** real-world vulnerabilities
- is submitted as **two** 15 pages PDF reports (30 pages total):
 - description of the affected program (e.g., architecture, components, implementation details, etc.)
 - description of the vulnerability type (e.g., recap of what is a SQL injection)
 - description of the vulnerability (e.g., how it works, where it is located in the code, etc.)
 - exploitation of the vulnerability (e.g., step by step for the reproduction, discussion of the exploit details, etc.)
 - reproduction of the vulnerability in a docker environment (e.g., detailed instructions to reproduce the vulnerability, output of the exploit, etc.)
 - mitigation of the vulnerability (e.g., how to fix the vulnerability, code changes, etc.)
 - reproduction of the fix in a docker environment (e.g., detailed instructions to reproduce the fix, output of the exploit, etc.)
- is evaluated based on 0-30 points scale:
 - 20 points for the reports
 - 10 points for reproduction environment

CVE Assignment

- Each student should pick one (or two when non compliant) CVE
 - Google query: **CVE program that you want to consider**
 - E.g., "Wordpress CVE", "Flask CVE", "n8n CVE", ...
 - You can consider even vulnerability types that have not been covered in the course
 - Understand whether there is enough material to analyze:
 - Source code (if the application is open source)
 - Vulnerability description
 - Exploit code
 - etc.

You **cannot** pick CVE-2022-21662, CVE-2022-28346, and CVE-2022-22818, since they will be discussed during the course.

- Check which CVEs have been already proposed by other students and thus cannot be considered by you: **URL**
- Submit your proposal via the form: **FORM**
- Check if your CVE has been approved: **URL**

When your proposal is approved, you can start working on the report(s).

Project Submission

You must submit:

- the PDF report(s)
- the related file required to reproduce your results (e.g., docker compose file, dockerfiles, scripts to run the exploit, the exploit itself, etc.)

using the form available on the course website: **FORM**

DEADLINE: 7 days before the exam date that you have chosen for your final exam.

Written exam and Project

During the written exam, you may one or two **technical** questions related to your project.